

AI Vendor Risk Assessment

Vendor: Anthropic (Claude AI Platform)

Framework: NIST AI Risk Management Framework (AI RMF 1.0)

Assessor: Mike Capela, CISSP • Date: September 2026

VERSION 2 — Incorporates human review, error analysis, and additional evidence sources.

Assessment methodology

This assessment was conducted through a structured, Claude-assisted analysis. Anthropic's publicly available vendor documentation was uploaded to Claude, which was prompted to extract controls and claims, map findings to an AI-specific risk questionnaire organized by the four NIST AI RMF core functions (Govern, Map, Measure, Manage) plus an AI Supply Chain section, pre-fill the questionnaire with cited evidence, and flag gaps for human review. The assessor then reviewed the output against source documents and documented errors. This manual process serves as a proof of concept for a repeatable, automated workflow.

Documents reviewed:

- **Trust Center** (trust.anthropic.com) — certifications matrix, compliance scope, subprocessor list
- **Data Processing Addendum (DPA)** — effective Feb 24, 2025
- **Usage Policy / Acceptable Use Policy** — effective Sep 15, 2025
- **Claude's Constitution** — published Jan 21, 2026
- **Privacy Policy**
- **Responsible Scaling Policy v3.4** — effective Jul 8, 2026 (added in v2)
- **Advanced AI Framework** — June 2026 (added in v2)
- **2025 Type 2 SOC 3 Report** — period Oct 2024–Sep 2025, publicly available (added in v2)
- **Independent third-party benchmarks** (Artificial Analysis — artificialanalysis.ai) (added in v2)

Documents NOT reviewed (behind request-access gate):

- **SOC 2 Type II report** — existence confirmed; detailed controls not assessed
- **ISO 27001 and ISO 42001 certificates** — existence confirmed
- **Model Documentation Forms** — listed on Trust Center

Scope limitation: this is a public-information assessment. The absence of internal governance details (escalation org charts, internal incident playbooks, named risk owners) is expected and appropriate — these are not documentation gaps but scope limitations. A full engagement under NDA would include access to gated materials and internal governance documentation.

GOVERN — Organizational governance for AI risk

G1. Does the vendor have a published AI governance policy or responsible AI framework? **[Supported]**

Evidence: Anthropic publishes a Responsible Scaling Policy (RSP v3.4, effective Jul 2026, 40+ pages with nine revisions since 2023), an Advanced AI Framework for policymakers (June 2026), and Claude's Constitution (Jan 2026, 85 pages). The RSP defines capability thresholds, escalating mitigation requirements, external review obligations, and governance commitments. The Constitution describes intended model behavior and values.

Gaps / Notes: The RSP is the strongest single governance document reviewed. Note that Claude's Constitution is a training document (written for Claude as its audience), not a traditional corporate governance policy with KPIs or review cadences. The two documents serve complementary purposes.

G2. Is there a named AI risk owner or governance body with defined accountability? **[Partially Supported]**

Evidence: The SOC 3 report names the CISO, President, CEO, CSO, and General Counsel with defined security responsibilities. The RSP references the Board of Directors and Long-Term Benefit Trust (LTBT) as governance bodies. Functional teams (Security Compliance, Safeguards, Observability, Security Engineering) are described with defined roles.

Gaps / Notes: Scope limitation: specific AI governance accountability (e.g., a named Chief AI Officer or AI Risk Committee) is not identified in public materials. The named C-suite roles have security responsibilities; whether a specific individual owns AI risk decisions is not publicly disclosed. This is typical for public-information assessments.

G3. Does the vendor have documented escalation paths for AI-related incidents? **[Supported]**

Evidence: The RSP v3 defines detailed escalation tied to capability thresholds: specific risk categories (biological weapons, cyber operations, loss of control, automated R&D) trigger escalating mitigations. Risk Reports are required every 3–6 months with defined content requirements and external review. Off-cycle updates are required for significant new capabilities. The Advanced AI Framework defines “Critical Safety Incident” with four specific categories and recommends 15-day government reporting. The DPA provides 48-hour Security Breach notification (contractual). The Usage Policy provides user-facing reporting channels.

Gaps / Notes: v1 rated this “Partially Supported” and noted internal escalation was not publicly visible. The RSP IS the published escalation framework. Rating upgraded.

G4. Does the vendor maintain AI-specific policies covering ethics, fairness, and responsible use? [Supported]

Evidence: Claude’s Constitution (85 pages covering behavioral values including honesty, harm avoidance, fairness, epistemic humility, and political neutrality), the Usage Policy (prohibited uses, high-risk use case requirements), and the RSP (responsible scaling commitments). The depth and specificity of Claude’s Constitution is genuinely unusual among AI vendors.

Gaps / Notes: No material gaps identified.

G5. Does the vendor conduct and publish AI risk assessments? [Supported]

Evidence: The RSP v3 requires published Risk Reports every 3–6 months covering: threat model identification, capability evaluations, mitigation descriptions, residual risk assessment, and external review. System cards are required for significant new model deployments. The Advanced AI Framework advocates for independent evaluation and government reporting. Model Documentation Forms are listed on the Trust Center (gated).

Gaps / Notes: v1 rated this “Partially Supported.” The RSP’s Risk Report requirements directly address this. Rating upgraded.

MAP — Context, scope, and known limitations

M1. Is the AI system’s intended use clearly defined and documented? [Supported]

Evidence: The Usage Policy defines both permitted and prohibited uses in detail, organized by Universal Usage Standards, High-Risk Use Case Requirements, and Additional Use Case Guidelines. Claude’s Constitution describes intended behavior, audience, and purpose.

Gaps / Notes: Anthropic positions Claude as a general-purpose AI assistant. Intended use is defined primarily through prohibited and restricted use categories rather than a narrow intended-use specification. This is consistent with the product’s general-purpose nature and is not a deficiency.

M2. Are known limitations and failure modes documented? [Partially Supported]

Evidence: Claude’s Constitution explicitly discusses limitations including hallucination risk and the gap between intended and actual behavior. Model Documentation Forms (gated) presumably contain detailed limitations.

Gaps / Notes: Limitations are acknowledged at a high level but not systematically quantified in public materials (e.g., hallucination rates, benchmark failure modes). Model Documentation Forms would contain this detail. This is consistent with industry practice for public-facing documentation.

M3. Is training data provenance disclosed? [Partially Supported]

Evidence: The Trust Center lists Training Data Summaries for multiple models (gated).

Gaps / Notes: Training data composition and sourcing methodology are not publicly detailed. This is an industry-wide gap, not unique to Anthropic. Scope limitation: training data details are appropriately restricted.

M4. Are third-party model dependencies or foundational-model provenance identified? [Supported]

Evidence: Anthropic develops its own foundational models, eliminating one layer of supply-chain risk. The Trust Center and SOC 3 distinguish between Anthropic-hosted and partner-hosted (AWS Bedrock, Google Vertex, Azure) deployments. Infrastructure dependencies (GCP, AWS, Azure) are disclosed via the subprocessor list.

MEASURE — Metrics, testing, and monitoring

ME1. Does the vendor publish evaluation metrics, benchmarks, or performance data? [Partially Supported]

Evidence: Independent third-party benchmarks are publicly available: Artificial Analysis (artificialanalysis.ai) publishes comprehensive, independently measured intelligence, speed, latency, and pricing metrics across all 31 Claude models. Anthropic publishes system cards and model announcements with benchmark results. The RSP requires Risk Reports with capability evaluation results. Model Documentation Forms (gated) presumably contain additional evaluation data.

Gaps / Notes: v1 rated this “Gated.” Performance benchmarks are publicly available through third-party sources. Safety evaluation metrics (adversarial robustness, red-team results) are less systematically published. Rating upgraded.

ME2. Is there documented bias or fairness testing? [Partially Supported]

Evidence: Claude’s Constitution addresses fairness extensively, including explicit instructions about political neutrality, stereotype avoidance, and equitable treatment. Anthropic publishes research on Constitutional AI, red-teaming, and bias mitigation on anthropic.com. The RSP commits to systematic alignment assessments.

Gaps / Notes: v1 rated this “Gated” despite having the Constitution in hand with extensive fairness guidance. Bias approach and methodology are publicly documented; quantified outcome data (specific bias metrics, disparate-impact measurements) is less systematically published. Rating upgraded.

ME3. Is there a monitoring plan for model drift, degradation, or emergent behavior? [Partially Supported]

Evidence: The RSP v3 establishes a structured framework for ongoing capability evaluation: defined capability thresholds triggering escalating mitigations, required Risk Reports every 3–6 months, commitments to systematic alignment assessments, “eyes on everything” state for internal AI development, and internal monitoring and behavioral restrictions.

Gaps / Notes: The governance framework for monitoring is well-documented. What remains less visible is the operational detail: specific metrics tracked, alerting thresholds, frequency of drift-detection scans, and how monitoring findings feed back into model updates. The framework is clear; the implementation specifics are not public.

ME4. Does the vendor engage independent third-party evaluators? [Supported]

Evidence: The 2025 SOC 3 report is publicly available on the Trust Center without access-gate restrictions. It confirms an independent auditor assessed Anthropic’s AI Services system against the Trust Services Criteria (security, availability, confidentiality, privacy) for the period Oct 2024–Sep 2025 and issued a clean opinion. The RSP v3 requires external review of Risk Reports. The Advanced AI Framework advocates for a licensed independent evaluator ecosystem. Anthropic submits systems for pre-deployment evaluation with US CAISI and UK AI Security Institute.

Gaps / Notes: The SOC 3 (auditor’s opinion, public) vs. SOC 2 (detailed controls, gated) distinction is a transparency observation: Anthropic makes the independent opinion freely available while keeping detailed test results restricted. This is standard industry practice.

MANAGE — Risk treatment and response

MA1. Is there a documented incident response plan for AI-specific failures? [Partially Supported]

Evidence: The RSP v3 defines escalation through capability thresholds with specific risk categories triggering different mitigations. The Advanced AI Framework defines “Critical Safety Incident” with four categories: unauthorized weight exfiltration, harm from catastrophic risk materialization, loss of control causing death/injury, and deceptive model behavior. The DPA provides 48-hour Security Breach notification. The SOC 3 confirms an incident response program with defined escalation levels and annual tabletop testing.

Gaps / Notes: Practitioner note: the DPA’s 48-hour breach-notification commitment is legally required boilerplate, standard across the industry. In practice, organizations routinely invoke the law enforcement investigation exception, which in most states has no fixed expiration — notification is delayed until law enforcement clears it. Statutory notification deadlines themselves range from 30 to 90 days depending on the state. The DPA term is a contractual floor, not an operational differentiator. What would constitute stronger evidence: published post-incident reports, disclosed response timelines from actual incidents, or independent audit of response-time performance.

MA2. Are there human-oversight mechanisms for AI system outputs? [Supported]

Evidence: Claude’s Constitution extensively describes the relationship between Claude’s autonomy and human oversight, including deferring to humans on consequential decisions, refusing harmful requests, and the operator/user trust hierarchy. The Usage Policy’s High-Risk Use Case Requirements imply human-in-the-loop requirements.

Gaps / Notes: Scope limitation: these are controls on Claude’s behavior, not on Anthropic’s internal development oversight. Internal oversight of the model development pipeline is appropriately not disclosed in public materials.

MA3. Is there a decommissioning, rollback, or model-retirement plan? [Not Addressed]

Evidence: No evidence of a formal model-retirement or rollback policy was found in any reviewed documentation.

Gaps / Notes: This finding is relevant for enterprise customers who need version stability and migration planning. However, the absence is consistent with how frontier AI vendors currently operate — an industry-wide immaturity, not an Anthropic-specific

governance failure. Anthropic's actual behavior (cautious staged releases, controlled access, deliberate rollout decisions) serves as a de facto lifecycle management approach.

MA4. Does the vendor have contractual commitments for data deletion and return? [Supported]

Evidence: The DPA (Section H) provides explicit data deletion and return terms: within 30 days of agreement termination, with defined exceptions. Processing restricted to specified business purposes (Section B). Prohibits selling, sharing, or combining customer data (Section B.3).

Gaps / Notes: The exception for "combating harmful use" (H.1.b.iii) is a potentially broad retention justification worth understanding during procurement.

AI SUPPLY CHAIN — Dependencies and concentration risk

SC1. Does the vendor disclose subprocessor relationships? [Supported]

Evidence: The Trust Center publicly lists subprocessors: GCP, AWS, Azure (cloud infrastructure, worldwide), Cloudflare (CDN, worldwide), TurboPuffer (web search, added May 2026). The DPA provides contractual subprocessor governance including 15-day change notification and customer objection rights.

SC2. Is there concentration risk in infrastructure or model providers? [Partially Supported]

Evidence: Multi-cloud (GCP, AWS, Azure) provides infrastructure diversification. The Trust Center's certification matrix shows different compliance scopes for different hosting environments. However, Anthropic is a single-model-family vendor — all products are Claude variants. Organizations with business-critical AI workloads on Claude have concentration risk at the model-provider level.

Gaps / Notes: Questionnaire gap identified during review: the subprocessor list identifies all three cloud providers as "worldwide." Public documentation does not clearly disclose whether customers can contractually restrict data processing to US-only infrastructure. Government customers subject to data sovereignty requirements (state agencies, CJIS-governed data) would need to clarify data residency controls during procurement. Deployment via AWS GovCloud or Azure Government may address this, but the distinction is not made in Anthropic's public documentation. A data sovereignty/residency question should be added to v2 of the questionnaire.

SC3. Does the vendor have business continuity and disaster recovery commitments? [Partially Supported]

Evidence: The DPA Schedule 2 confirms a BC/DR plan tested annually. The SOC 3 provides detailed backup, disaster recovery, and replication information, independently verified. Automated daily backups, 30-day retention, geographic replication, and annual DR testing confirmed.

Gaps / Notes: Specific RTOs, RPOs, and availability SLAs are not detailed in public materials. These would be critical for availability-sensitive AI workloads and should be addressed during procurement.

Summary of findings

Ratings overview (v1 → v2 changes noted):

- **Supported (10, up from 7):** G1, G3 ↑, G4, G5 ↑, M1, M4, ME4, MA2, MA4, SC1. Key upgrades: G3 and G5 moved from Partially Supported after RSP v3 review provided strong evidence of published escalation and risk-assessment frameworks.
- **Partially Supported (7, down from 8):** G2, M2, M3, ME1 ↑, ME2 ↑, ME3, MA1, SC2, SC3. Key upgrades: ME1 and ME2 moved from Gated after identifying publicly available third-party benchmarks and published bias/fairness research.
- **Gated (0, down from 2):** No questions remain rated Gated. Both former Gated ratings (ME1, ME2) upgraded after identifying public evidence sources.
- **Not Addressed (1, unchanged):** MA3 — no model-retirement/rollback policy. Reframed as industry-wide immaturity.

Key strengths

- **Responsible Scaling Policy v3** is an unusually detailed, publicly available governance framework with defined capability thresholds, escalating mitigations, external review requirements, and a nine-revision changelog dating to 2023.
- **Claude's Constitution** is the most detailed published articulation of intended AI behavior among major vendors.
- **Data Processing Addendum** is thorough, with strong deletion/return terms and subprocessor governance.
- **Compliance posture is broad:** SOC 2 Type II, ISO 27001, ISO 42001, CSA STAR, HIPAA, FedRAMP High, NIST 800-171.
- **Transparency posture is strong:** SOC 3 publicly available without NDA, RSP published with full version history, Constitution released under CCO.

Key gaps and recommendations for procurement

- **Data sovereignty:** subprocessor list shows “worldwide” for all infrastructure providers. Government and regulated-industry customers should clarify data residency controls during procurement.
- **Model retirement:** no formal deprecation/rollback policy. Recommend contractual terms requiring deprecation notice and migration support.
- **Quantified safety metrics:** bias testing methodology is documented; quantified outcomes are not systematically published. Request during NDA-protected review.
- **Incident response reality vs. contract:** DPA breach-notification terms are standard boilerplate. Evaluate actual incident-response capability through NDA-protected review of the SOC 2 and any published post-incident reports.

Error analysis — Where the AI got it wrong

The following analysis documents every significant error, misrating, or framing issue identified during human review of the Claude-assisted first pass (v1). This section is the core of the proof of concept: it demonstrates where human judgment was required to correct, reframe, or supplement the AI's output.

Summary of error patterns

Three systematic patterns emerged, each revealing a different limitation of using an LLM for vendor risk assessment:

- **1. Wrong audit lens (GOVERN, MANAGE):** Claude applied an internal-audit standard to a public-information assessment, repeatedly flagging the absence of internal governance details as deficiencies. A practitioner with audit experience recognizes that public-facing documentation is not expected to disclose internal escalation structures, named risk owners, or incident playbooks. These are scope limitations, not findings.
- **2. Evidence scope limited to uploaded documents (MEASURE):** Claude only assessed what was uploaded. It did not search for publicly available third-party evaluation data (Artificial Analysis benchmarks) or vendor-published research (Anthropic's bias and Constitutional AI papers). A competent human assessor naturally searches beyond the vendor's trust center. An automated workflow would need a web-search step.
- **3. Overweighting boilerplate (MANAGE):** Claude cited the DPA's 48-hour breach notification as meaningful evidence of incident-response capability. A cybersecurity practitioner knows this is legally required boilerplate that does not reflect real-world breach-response timelines. The law enforcement investigation exception, which has no fixed expiration in most states, routinely delays disclosure well beyond any contractual commitment.

Detailed error log

Ref	Error type	What Claude said (v1)	What was actually true	How the assessor caught it
Meth.	Overstatement	"Claude-powered workflow"	Structured Claude-assisted analysis — a conversation with uploaded documents, not an automated workflow	Assessor recognized that uploading documents and chatting is not a repeatable workflow; honest reframe
G1–G5	Pattern: wrong audit lens	Repeatedly flagged absence of internal governance details (escalation paths, named risk owners, internal policies) as deficiencies	These are expected scope limitations of a public assessment. No vendor publishes internal escalation org charts. Doing so could be a security risk.	Assessor's cybersecurity and audit experience: internal governance details are appropriately internal, not a documentation gap
G3	False negative	"Internal escalation framework is not publicly visible"	The RSP v3 IS a published escalation framework with defined capability thresholds, required Risk Reports, and external review	RSP v3 reviewed in Session 3; evidence was missing from the first-pass document set
G5	False negative	"Does not itself publish detailed risk assessment results"	RSP v3 requires published Risk Reports every 3–6 months with defined contents, external review, and off-cycle updates	RSP v3 reviewed in Session 3
M1	Overstated concern	"Positive use-case documentation is less structured"	Claude is a general-purpose AI assistant. Defining intended use through prohibited-use boundaries is the appropriate approach for a general-purpose product, not a gap.	Assessor recognized that narrow intended-use documentation applies to specialized tools, not general-purpose AI
ME1	False negative	Rated "Gated" — evaluation metrics not available	Independent third-party benchmarks (Artificial Analysis) are publicly available with comprehensive performance data across all Claude models. Anthropic also publishes system	Assessor searched beyond vendor's own documentation; Claude only assessed uploaded documents

Ref	Error type	What Claude said (v1)	What was actually true	How the assessor caught it
			cards and model announcements.	
ME2	False negative	Rated "Gated" — bias testing not available	Claude's Constitution (already in hand) contains extensive fairness/bias guidelines. Anthropic publishes research on Constitutional AI and bias mitigation on anthropic.com.	Assessor recognized that evidence was underweighted from a document already reviewed, and that additional public research exists
ME3	Unclear gap note	Original note hedged about RSP "referenced but not reviewed," resulting in awkward assessment	With RSP v3 now reviewed: governance framework for monitoring is well-documented; operational implementation details are not public	Assessor identified the note as unclear post-review; rewritten for specificity
MA1	Overweighted boilerplate	Cited DPA 48-hour breach notification as meaningful evidence of incident response capability	DPA breach-notification language is legally required boilerplate. In practice, organizations invoke the law enforcement exception, which has no fixed expiration in most states. The DPA term is a compliance artifact, not an operational differentiator.	Assessor's cybersecurity incident-response experience: knows the gap between contractual terms and real-world breach response
MA3	Framing error	"Not Addressed" presented as a governance gap	Correct that no formal retirement policy exists. However, the absence is consistent with how frontier AI vendors currently operate — an industry-wide immaturity, not an Anthropic-specific failure.	Assessor recognized the finding needs context: relevant for enterprise customers, but not a vendor deficiency
SC2	Questionnaire gap	No question about data sovereignty or geographic processing restrictions	Subprocessor list shows all providers as "worldwide." No publicly documented mechanism for customers to restrict processing to US-only infrastructure. Material concern for government customers.	Assessor identified gap during review based on knowledge of government procurement requirements

Questionnaire design improvement identified

During review, the assessor identified a missing question: the v1 questionnaire did not ask about data sovereignty or geographic processing restrictions. Given that the subprocessor list shows “worldwide” for all infrastructure providers, this is a material omission for government and regulated-industry customers. Recommended addition for v2: “Can customers contractually restrict data processing to specific geographic regions?”

What Claude got right

For completeness, the error analysis should note what the AI did well:

- **Document inventory:** Claude correctly identified which documents were reviewed and which were gated. No hallucinated documents.
- **Evidence extraction:** factual claims about document contents were accurate across all 18 questions. No hallucinated controls, no fabricated citations.
- **Framework mapping:** the NIST AI RMF categorization (Govern/Map/Measure/Manage) was appropriate for all questions.
- **Rating calibration:** where evidence existed in the uploaded documents, ratings were defensible. Errors were primarily in scope/framing, not in factual accuracy.

Conclusion: the Claude-assisted analysis produced a structurally sound, factually accurate first draft that required human correction primarily in scope judgment, evidence sourcing, and practitioner context — not in factual accuracy. This supports the use of LLM-assisted assessment as a time-saving tool, provided the human reviewer brings domain expertise and is specifically looking for framing errors, scope misapplication, and evidence the AI could not access.

Assessor: Mike Capela, CISSP • Prompt version: v2.0 • Assessment date: September 2026

v1: August 2026 (Claude-assisted first pass). v2: September 2026 (human-reviewed, error-corrected, additional evidence incorporated).